

NutriAgent: Comprehensive Project Report

A Distributed Multi-Agent AI Clinical Nutrition & Meal Planning Advisory System Grounded in Verified Retrieval

Course: IT3041 Information Retrieval & Web Analytics	Institution: Sri Lanka Institute of Information Technology (SLIIT)
Academic Year: Year 3, Semester 2	Architecture Pattern: Synchronous Chained HTTP Microservices
Core Technologies: FastAPI, spaCy NER, ChromaDB, Sentence-Transformers, Google Gemini Generative AI, SQLite, SlowAPI	Interface: Dark-Mode AI Chat Workspace & Gateway Dashboard

1. Executive Summary & Clinical Problem Statement

Standard commercial Large Language Models (LLMs) such as ChatGPT or Claude demonstrate remarkable fluency but suffer from a fatal flaw in clinical healthcare: **hallucination of quantitative nutrition facts**. LLMs routinely invent calories, fabricate protein/carbohydrate distributions, and fail to guarantee deterministic allergen elimination—presenting life-threatening risks to individuals with anaphylactic food allergies, diabetes, or hypertension.

NutriAgent addresses this challenge by pioneering a **decoupled Multi-Agent Architecture**. It separates factual nutritional Information Retrieval (IR) from Generative AI Reasoning. A dedicated Nutrition IR Agent retrieves verified whole-food records from official USDA FoodData Central databases and applies deterministic hard-exclusion filters. The Meal Planning Agent is strictly constrained to reason only over these verified foods, synthesizing personalized recipes, cooking tips, and dynamic condition-specific disclaimers without hallucination.

2. System Architecture & Inter-Agent Communication

The NutriAgent ecosystem comprises four autonomous FastAPI microservices running in isolated processes, communicating via a **Synchronous Chained HTTP Pattern** governed by a single contract (shared/schemas.py):

Agent / Service	Port	Primary Responsibility & Internal Technology	Input → Output Contract
1. Security Gateway	8001	Zero-Trust Perimeter, PBKDF2 User Store, JWT Verification, Universal Prompt Injection & Admin Command Defense, SlowAPI, Web UI.	SecurityRequest → IntakeRequest
2. Intake & Profile	8002	spaCy EntityRuler NLP, Windowed Negation Engine, Calorie Target Parser, SQLite Profile Persistence Store (profiles.sqlite3).	IntakeRequest → UserProfile
3. Nutrition IR	8003	ChromaDB Vector Store, sentence-transformers embeddings, USDA FoodData Central, Deterministic Hard Allergen Exclusion Filter.	IRRequest → IRResponse (FoodItem[])
4. Meal Planning	8004	Google Gemini Generative AI (Flash models), Grounded Reasoning, Culinary Recipe & Prep Guidance, Dynamic Disclaimers, Synchronized Fallback.	PlanningRequest → MealPlan

Distributed Tracing Architecture: Every request entering the Security Gateway receives a canonical UUID4 X-Trace-ID header. This header is propagated synchronously across all four microservices. Structured request logs record timestamps, latency (ms), HTTP method, and response status linked by the trace ID without logging sensitive health data or user credentials.

3. Detailed Microservice Agent Implementations

3.1 Security & Validation Agent (Port 8001)

The Security Agent serves as the public gateway and authentication firewall for the entire cluster. Key technical components include:

- **PBKDF2-HMAC-SHA256 Authentication:** User credentials in `security_agent/database.py` are protected with unique 16-byte cryptographic salts and 310,000 hash iterations stored in SQLite (`nutriagent.db`). Mitigates rainbow table and pre-computation attacks.
- **JWT Token Security:** Issues and validates cryptographically signed JSON Web Tokens using HS256 with 30-minute expiration. The verified subject (sub) must strictly match the body `user_id` (403 Forbidden check). Strips JWT tokens before internal forwarding.
- **Universal Prompt Injection Defense:** Multi-stage normalization and pattern matching in `security_agent/validation.py`. Intercepts instruction overrides, persona hijacking (DAN mode), prompt exfiltration, and delimiter spoofing. Employs Unicode NFKD normalization and leetspeak translation (`@ -> a`, `0 -> o`) to prevent obfuscation bypasses.
- **Administrative & Destructive Command Guard:** Intercepts harmful administrative actions (delete user, drop database, remove account, truncate table, kill process, format c:) with immediate HTTP 400 rejection, while preserving legitimate food statements (e.g. `'drop body fat'` or `'delete sugar'`).
- **SlowAPI Rate Limiting:** Enforces per-client-IP rate quotas (5 login/min, 10 process/min), protecting backend resources against Denial-of-Service.

3.2 Intake & Profile Agent (Port 8002)

The Intake Agent translates unstructured natural language into structured clinical profiles using rule-based natural language processing:

- **spaCy EntityRuler Taxonomy:** Configures deterministic phrase patterns matching 5 essential nutritional categories: 9 Allergies (peanut, tree nuts, shellfish, dairy, gluten, eggs, soy, sesame, fish), 5 Chronic Conditions (type 1/2 diabetes, hypertension, celiac disease, kidney disease, lactose intolerance), 4 Goals (weight loss, muscle gain, maintenance, health), 5 Diets (vegan, vegetarian, keto, pescatarian, halal), and 4 Preferences (high protein, low carb, low sodium, quick meals).
- **Windowed Lookbehind Negation Engine:** Analyzes preceding 32-character and trailing context windows to identify negative phrasing (`_is_negated`), preventing phrases like `'I have no dairy allergy'` from falsely flagging a restriction.
- **Quantitative Calorie Parser:** Extracts numerical energy targets via boundary-aware regular expressions (e.g. `'about 2200 kcal'` → 2200).
- **Persistent Profile Merging:** Stores profiles in SQLite (`profiles.sqlite3`). When returning users provide incremental adjustments (`'I now eat vegetarian'`), `merge_profiles()` updates preferences while safeguarding existing chronic allergies.

3.3 Nutrition Information Retrieval (IR) Agent (Port 8003)

The Nutrition IR Agent provides the empirical foundation of the system, replacing generative guesswork with grounded data retrieval:

- **Dense Semantic Embeddings:** Employs the sentence-transformers/all-MiniLM-L6-v2 model to generate 384-dimensional dense semantic vectors from food titles, preparation methods, and ingredient strings.
- **ChromaDB Vector Store:** Manages high-performance cosine similarity nearest-neighbor indexing over verified food records sourced from USDA FoodData Central and curated whole-food recipe datasets (foods.csv, epi_r.csv).
- **Deterministic Hard-Filtering Safety Layer:** Executes strict boolean set-difference filtering on all candidate items to eliminate user allergens (e.g., completely dropping any food containing peanuts, tree nuts, or shellfish) before sending items to the planning agent.
- **Grounded Macronutrient Metadata:** Attaches verified calories, protein (g), carbohydrates (g), fat (g), and official USDA source attribution to every retrieved item.

3.4 Meal Planning & Reasoning Agent (Port 8004)

The Planning Agent synthesizes the user profile and grounded foods into an actionable, explainable meal plan:

- **Google Gemini Generative AI Integration:** Invokes Gemini Flash models (gemini-2.5-flash, gemini-2.0-flash) using Google's official google-gemai SDK.
- **Anti-Hallucination Grounding Prompt:** Explicitly instructs the LLM that retrieved items are immutable data. The model is forbidden from inventing foods or altering calorie numbers; its responsibility is limited to reasoning and culinary explanation.
- **Culinary Enrichment & Recipes:** Generates whole-food ingredient breakdowns (3-5 items) and actionable Chef's preparation tips (prep_tip) for cooking, seasoning, and texture balance.
- **Sharp Allergen Verification Shield:** Emits an explicit allergen_safety_note detailing exactly which user allergens were cross-checked and eliminated.
- **Dynamic Condition-Tailored Disclaimers:** Replaces generic notices with clinical guidance generated by generate_dynamic_disclaimer() (e.g. sodium monitoring for hypertension, glycemic balance for diabetes, certified gluten-free packaging notices for celiac disease).
- **Synchronized Resilient Fallback Engine:** Includes an automated deterministic rule-based planner that generates complete meal plans with macros, recipes, and disclaimers if Gemini API quotas are exhausted or the network is offline.

4. Modern Web Client & AI Chat Workspace

NutriAgent delivers a unified, dark-mode single-page application hosted directly by the Security Gateway at http://localhost:8001:

- **Animated Multi-Agent Pipeline Visualizer:** Shows real-time progression through Security (Sanitization) → Intake (Profile Extraction) → IR (USDA Retrieval) → Planning (AI Reasoning).
- **Interactive Meal Cards:** Features calorie badges, macronutrient pills (■ Protein, ■ Carbs, ■ Fat), and an expandable Culinary Preparation Drawer with Chef's cooking advice.
- **Safety Shield & Dynamic Disclaimer Badges:** Displays prominent green allergen safety certification and amber medical advisory notices.
- **In-Chat Security Alerts:** Real-time red notifications explaining prompt injection or administrative command rejections without crashing the UI.
- **Security Audit Logs Modal:** Authenticated users can inspect their recent login history, IP addresses, timestamps, and request trace IDs (/api/audit-logs).

5. Responsible AI, Clinical Safety & Ethical Governance

NutriAgent incorporates five foundational Responsible AI principles:

Pillar	Risk Addressed	NutriAgent Architectural Mitigation
--------	----------------	-------------------------------------

1. Grounding & Anti-Hallucination	Fabrication of false calorie and macro statistics by generative LLMs.	Retriever-Augmented Generation (RAG). Foods are retrieved from verified USDA databases; the LLM is restricted to reasoning over retrieved facts.
2. Life-Critical Allergen Safety	Fatal allergic reactions (anaphylaxis) from missed ingredients.	Deterministic boolean set filtering in the IR Agent; sharp verification note confirming safe exclusion.
3. Ethical & Legal Boundaries	Unlicensed medical practice or dangerous dietary prescriptions.	Dynamic condition-specific disclaimers emphasizing that AI advice does not supersede licensed physician guidance.
4. Adversarial Defense	Prompt injection, jailbreak attempts, and system hijacking.	Zero-Trust Security Gateway regex filters blocking instruction overrides, DAN mode, and destructive commands (e.g. delete user).
5. Privacy & Data Minimization	Data leakage of user credentials and medical queries.	Salted PBKDF2 hashing, JWT token stripping at the gateway, and structured JSON logs that omit personal health queries.

6. Commercialization, Unit Economics & SaaS Pricing Strategy

NutriAgent is designed with highly favorable unit economics, positioning it as an ideal SaaS solution for both direct-to-consumer (B2C) and clinical healthcare (B2B) markets:

Resource / Infrastructure	Unit Cost Structure	Gross Margin / Operational Impact
Google Gemini 2.0 Flash API	\$0.10 / 1M input tokens \$0.40 / 1M output tokens	< \$0.0005 per generated meal plan! Exceptional gross margin exceeding 95%.
Cloud Microservices (AWS/GCP)	Containerized ECS Fargate / Cloud Run (~\$35/month)	Scales to zero when idle; auto-scales dynamically during peak meal planning hours.
Vector Storage & Database	Chroma Cloud / persistent EBS (~\$15/month)	Predictable low-cost indexing for 100,000+ food items.

Market Monetization Tiers:

- **Free Tier (\$0/month):** 3 meal plan generations per day, basic calorie and allergen filtering. Functions as customer acquisition funnel.
- **Pro Tier (\$9.99/month or \$79/year — B2C):** Unlimited meal plans, Chef's recipe preparation tips, macro breakdown pills, family allergen profiles, and exportable grocery shopping lists.
- **Clinic & Dietitian Tier (\$99.00/month per practitioner — B2B):** Dietitian dashboard, patient EHR integration, custom clinical nutrition constraints, audit logs, and branded PDF exports for clinic patients.

7. System Verification & Automated Test Results

NutriAgent maintains comprehensive unit, regression, and integration test coverage across all microservice layers:

Test Suite Module	Tests Run	Key Validations Executed	Status
security_agent/tests/test_validation.py	6 test cases (25+ variants)	Prompt injection, DAN mode, system prompt leakage, Unicode de-obfuscation, administrative commands (delete user), boundary lengths.	100% PASSED

security_agent/tests/test_database.py	19 test cases	Salted PBKDF2 password hashing, registration, duplicate prevention, audit log recording, static Web UI serving.	100% PASSED
tests/test_intake_agent.py	3 test cases	spaCy EntityRuler taxonomy extraction, windowed negation discarding, intent classification, SQLite profile merging.	100% PASSED
security_agent/tests/test_auth.py & test_rate_limiting.py	60+ test cases	JWT signing/expiry, subject validation, SlowAPI IP-based quotas, 429 excess status handling.	100% PASSED

8. Conclusion & Future Directions

NutriAgent successfully proves that combining **Empirical Information Retrieval** with **Generative AI Reasoning** under a **Zero-Trust Security Perimeter** produces an accurate, clinically safe, and commercially viable nutrition advisory platform. Future enhancements include integration with Apple Health / Google Fit APIs, computer-vision meal photo logging, and multilingual clinical NLP expansion.